

杨凌国合外贸综合服务平台 1.0 复查报告

由 Markdown 阅读资料转换生成 · 通用自适应阅读版 · 适合转发和专家审阅

杨凌国合外贸综合服务平台 1.0 复查报告

复查日期：2026-04-25 项目路

径：/Users/wangbin/Documents/Codex/review_src2/autoWorkPlatform-v1.0.0 复查对象：源码、数据库脚本、部署包、需求文档、前后端构建结果、Docker MySQL 运行环境、接口冒烟测试结果

1. 总体结论

本次是在本机环境已经安装完成以后重新复查。结论比第一次更明确：

- 平台 1.0 已经可以完成前后端编译打包，说明基础工程能够构建。
- 后端可以启动，登录接口可用，部分基础 CRUD 接口可用。
- 但是数据库脚本与代码严重不一致，导致模板、报关、进口台账等关键模块运行时报错。
- 目前版本更接近“演示型 MVP”，不适合直接作为省级外贸综合服务平台生产上线。
- 按需求文档 V1.0 来看，已有部分模块达到了页面和基础接口层面的实现，但仍有多项验收风险。
- 按“国有农产品外贸企业 + 省级外贸综合服务平台”的目标来看，业务闭环、数据治理、权限安全、外部系统衔接、风控和监管能力都需要重构式提升。

一句话判断：

当前 1.0 可以作为内部演示和原型验证，但必须先完成数据库一致性、安全整改、权限模型、部署规范和业务闭环补强，才能进入试点运行。

2. 本机环境与验证结果

2.1 已安装环境

本机已确认：

项目	状态	版本/说明
Java	已安装	OpenJDK 17.0.19
Maven	已安装	Maven 3.9.15
Node.js	已安装	v23.11.0
npm	已安装	10.9.2
Docker Desktop	已安装并运行	Docker 29.4.0
MySQL	已通过 Docker 安装	mysql:8.0, 容器名 trade-platform-mysql
数据库	已创建	trade_platform
初始化 SQL	已导入	当前创建 14 张表

2.2 构建结果

后端构建：

```
mvn -Dmaven.test.skip=true package
BUILD SUCCESS
```

生成文件：

```
backend/target/trade-platform-1.0.0.jar
```

前端构建：

```
npm run build
✓ built
```

生成目录：

```
frontend/dist
```

2.3 后端真实启动结果

后端已真实启动成功：

```
Tomcat started on port(s): 8081
Started TradePlatformApplication
```

当前连接数据库：

```
jdbc:mysql://localhost:3306/trade_platform
username: root
password: root
```

配置位置：

```
backend/src/main/resources/application.yml
```

2.4 接口冒烟测试结果

运行项目自带脚本：

```
tests/check_all_apis.py
```

结果：

```
45 个接口
38 个正常
7 个报错
```

主要失败：

模块	接口	失败原因
配置	/api/config/values/by-item-code	初始化数据缺少 COUNTRY 配置项
模板	/api/templates/by-type	biz_template 缺少 file_path 等字段
模板	/api/templates/1	biz_template 缺少 file_path 等字段
报关	/api/customs/list	biz_customs_declaration 缺少 deleted 字段
报关	/api/customs/list	同上
报关	/api/customs/list	同上
登录错误场景	/api/auth/login	返回 code=500，不是业务错误码

补充测试进口台账：

```
POST /api/ledger/list
GET /api/ledger/1
```

均失败：

```
Table 'trade_platform.biz_import_ledger' doesn't exist
```

3. 项目现状概览

3.1 技术栈

后端：

- Java
- Spring Boot 2.7.18
- MyBatis-Plus 3.5.5
- MySQL 8

- JWT
- Lombok
- Apache POI / EasyExcel
- OnlyOffice 相关接口

前端：

- Vue 3
- Vite 8
- Element Plus
- Pinia
- Vue Router
- Axios

部署：

- 当前包含 jar 包、前端 dist、Nginx 配置、Windows bat 启停脚本、SQL 脚本。
- 暂无标准 Dockerfile / docker-compose。
- 暂无 CI/CD 配置。

3.2 已实现模块

源码中已有以下模块：

- 登录注册
- 用户管理
- 用户审批
- 租户管理
- 配置管理
- 模板管理
- 合同管理
- 商品管理

- 订单管理
- 报关单管理
- 文件管理
- 供应商/客户管理
- 退税展示页
- 进口台账
- 单据生成
- OnlyOffice 在线编辑回调

3.3 与需求文档的关系

需求文档定位是：

面向关贸业务的多租户 SaaS 系统，实现用户、合同、订单、报关单、文件等核心业务线上管理。

需求文档还明确：

- 当前版本暂不包含与第三方外部系统的自动数据交互或 API 集成。
- 退税管理模块只要求静态展示页，无逻辑代码。

因此需要区分两件事：

1. 按 V1.0 需求验收：目前仍有数据库、权限、接口失败等硬伤。
2. 按省级外综服平台目标建设：当前需求范围本身就偏小，需要重新规划 2.0。

4. P0 级问题：必须优先整改

P0 是“影响系统启动、关键功能运行、数据安全或上线合规”的问题。

P0-1 数据库脚本与代码严重不一致

这是当前最大问题。

现象

后端能启动，但多个模块运行时报 SQL 错误。

数据库当前只有 14 张表：

```
biz_contract
biz_customs_declaration
biz_customs_goods
biz_file
biz_goods
biz_order
biz_order_goods
biz_partner
biz_template
sys_config_item
sys_config_value
sys_tenant
sys_user
sys_user_apply
```

但是源码中已经使用了更多表和字段。

缺失表

代码引用：

```
backend/src/main/java/com/trade/platform/module/ledger/entity/ImportLedger.java
@Table("biz_import_ledger")
```

```
backend/src/main/java/com/trade/platform/module/ledger/entity/ImportLedgerGoods.java
@Table("biz_import_ledger_goods")
```

```
backend/src/main/java/com/trade/platform/module/ledger/entity/ImportLedgerFile.java
@Table("biz_import_ledger_file")
```

```
backend/src/main/java/com/trade/platform/module/customs/entity/CustomsReview.  
java  
@TableName("biz_customs_review")
```

但是 SQL 初始化文件没有这些表。

缺失字段

Template 实体有这些字段：

```
backend/src/main/java/com/trade/platform/module/template/entity/Template.java  
filePath  
fileName  
fileSize  
pdfPath
```

但是数据库 biz_template 实际只有：

```
id  
type  
name  
description  
html_content  
deleted  
create_time  
update_time
```

所以模板接口真实运行时报：

```
Unknown column 'file_path' in 'field list'
```

CustomsDeclaration 实体有这些字段：

```
ledgerId  
splitSeq  
reviewStatus  
submitTime
```



```
submitBy  
reviewTime  
reviewBy  
deleted
```

但是数据库 `biz_customs_declaration` 实际没有这些字段。

所以报关接口真实运行时报：

```
Unknown column 'deleted' in 'where clause'
```

影响

- 模板管理部分接口不可用。
- 报关单列表不可用。
- 进口台账不可用。
- 报关审核记录不可用。
- 单据生成相关流程存在连锁风险。

整改建议

立即补齐数据库迁移脚本，至少包括：

- `biz_import_ledger`
- `biz_import_ledger_goods`
- `biz_import_ledger_file`
- `biz_customs_review`
- `biz_template.file_path`
- `biz_template.file_name`
- `biz_template.file_size`
- `biz_template.pdf_path`
- `biz_customs_declaration.ledger_id`
- `biz_customs_declaration.split_seq`

- `biz_customs_declaration.review_status`
- `biz_customs_declaration.submit_time`
- `biz_customs_declaration.submit_by`
- `biz_customs_declaration.review_time`
- `biz_customs_declaration.review_by`
- `biz_customs_declaration.deleted`

建议引入：

- Flyway 或 Liquibase
- `V1__init.sql`
- `V2__template_file_columns.sql`
- `V3__ledger_tables.sql`
- `V4__customs_review_workflow.sql`

以后不能只维护一个 `init.sql`，必须使用版本化迁移。

P0-2 初始化数据不完整

现象

接口：

```
GET /api/config/values/by-item-code?code=COUNTRY
```

返回：

```
配置项不存在
```

影响

- 前端下拉框可能没有国别、海关、贸易方式等基础数据。
- 合同、订单、货物、报关导入流程会缺少基础字典。

- 测试脚本中已有对 `COUNTRY` 的接口检查，但 SQL 未初始化。

整改建议

补齐基础配置项：

- 国家/地区
- 币种
- 港口
- 海关
- 贸易方式
- 运输方式
- 监管方式
- 业务文件类型
- 合同状态
- 订单状态
- 报关状态

基础数据要单独建脚本，例如：

```
V5__seed_config_items.sql  
V6__seed_config_values.sql
```

P0-3 权限模型与需求不一致

需求要求

需求文档中写明：

- 系统管理员拥有最高权限。
- 国合员工拥有除配置管理、模板管理外的全部权限。
- 企业员工只能访问本企业数据。

代码现状

用户列表、状态修改、重置密码等接口只允许 **ADMIN**：

```
backend/src/main/java/com/trade/platform/module/user/controller/UserController.java
@RequireRole("ADMIN")
```

用户审批只允许 **ADMIN**：

```
backend/src/main/java/com/trade/platform/module/user/controller/UserApplyController.java
@RequireRole("ADMIN")
```

租户管理也只允许 **ADMIN**：

```
backend/src/main/java/com/trade/platform/module/tenant/controller/TenantController.java
@RequireRole("ADMIN")
```

但前端路由却把部分页面开放给 **GUOHE**：

```
frontend/src/router/index.js
roles: ['ADMIN', 'GUOHE']
```

这说明前后端权限口径不一致。

影响

- 国合员工即使前端能看到菜单，调用后端也可能被拒绝。
- 需求验收时会出现“页面有权限、接口没权限”的问题。
- 权限设计没有体现真实岗位分工。

整改建议

短期：

- 把用户审批、租户查询、租户审核等接口允许 **ADMIN** 和 **GUOHE**。

- 配置管理、模板管理仍仅允许 `ADMIN` 。
- 企业员工只能操作本租户数据。

中期：

- 建立标准 RBAC 表：
- `sys_role`
- `sys_permission`
- `sys_user_role`
- `sys_role_permission`
- `sys_menu`
- `sys_operation_log`

长期：

- 不只做角色判断，还要做：
- 按租户隔离
- 按部门隔离
- 按业务单据状态控制操作
- 按审批节点控制操作

P0-4 注册角色由前端提交，存在越权风险

代码证据

注册 DTO 要求前端传角色：

```
backend/src/main/java/com/trade/platform/module/user/dto/RegisterDTO.java  
role
```

注册服务直接保存：

```
backend/src/main/java/com/trade/platform/module/user/service/UserService.java
apply.setRole(dto.getRole())
```

审批通过时直接使用申请中的角色创建用户：

```
backend/src/main/java/com/trade/platform/module/user/service/UserService.java
user.setRole(apply.getRole())
```

影响

如果前端或接口调用者提交 **ADMIN**，审批人员误点通过，就可能创建管理员账号。

整改建议

- 普通注册只能申请 **ENTERPRISE**。
- 国合员工账号必须由管理员邀请或创建。
- 管理员账号必须由初始化脚本或超级管理员创建。
- 审批页面必须显示角色风险提示。
- 后端必须校验申请角色是否允许。

P0-5 JWT 过期时间计算错误

代码证据

```
backend/src/main/java/com/trade/platform/security/JwtUtil.java
Date expiryDate = new Date(now.getTime() + expiration * 1000)
```

配置：

```
jwt.expiration: 86400000
```

如果 **86400000** 是毫秒，本应是 24 小时，但代码又乘以 1000，实际接近 1000 天。

影响

- Token 泄露后的有效期过长。
- 离职账号、被盗账号风险扩大。
- 不满足生产安全要求。

整改建议

- 明确单位：秒或毫秒只能选一种。
 - 建议配置：
 - Access Token：2 小时
 - Refresh Token：7 至 14 天
 - 增加主动失效机制：
 - 修改密码后失效
 - 禁用用户后失效
 - 退出登录后失效
-

P0-6 默认密码和重置密码不安全

代码证据

默认管理员：

```
sql/init.sql  
admin / admin123
```

重置密码固定为：

```
backend/src/main/java/com/trade/platform/module/user/service/UserService.java  
123456
```

影响

- 默认账号容易被猜中。

- 重置后大量用户可能共用同一弱密码。
- 不符合国企平台安全基线。

整改建议

- 初始化管理员时生成随机强密码。
 - 首次登录强制修改密码。
 - 重置密码改为一次性随机密码或重置链接。
 - 增加密码复杂度策略：
 - 至少 10 到 12 位
 - 包含大小写、数字、特殊字符
 - 不能与用户名、手机号相似
 - 增加登录失败锁定和验证码。
-

P0-7 OnlyOffice 回调存在 SSRF 和未授权文件替换风险

代码证据

OnlyOffice callback 被排除 JWT：

```
backend/src/main/java/com/trade/platform/config/WebMvcConfig.java
/api/templates/onlyoffice/callback
```

回调中读取请求体的 `url` 并直接下载：

```
backend/src/main/java/com/trade/platform/module/template/controller/OnlyOfficeController.java
new URL(downloadUrl).openConnection()
```

影响

攻击者可能伪造回调，让服务器访问内网地址，或者覆盖模板文件。

整改建议

- 启用 OnlyOffice JWT。
 - 校验回调 token。
 - 校验文档 key 和模板 ID 的绑定关系。
 - 限制下载 URL 只能来自可信 Document Server。
 - 禁止访问内网、localhost、云元数据地址。
 - 替换文件前做文件类型、大小、hash 校验。
 - 保留模板历史版本。
-

P0-8 全局异常把内部错误返回给前端

代码证据

```
backend/src/main/java/com/trade/platform/common/GlobalExceptionHandler.java  
return Result.error("系统内部错误: " + e.getMessage())
```

真实接口测试中已经暴露 SQL：

```
Unknown column 'file_path' in 'field list'  
Unknown column 'deleted' in 'where clause'
```

影响

- 泄露数据库结构。
- 泄露 Java 类名、SQL、路径。
- 方便攻击者分析系统。

整改建议

- 前端统一返回：
- 系统繁忙，请稍后再试
- 错误码

- traceId
 - 后端日志记录完整异常。
 - 业务异常和系统异常分开处理。
-

5. P1 级问题：影响试点质量和安全

P1-1 CORS 配置过宽

代码证据

```
backend/src/main/java/com/trade/platform/config/CorsConfig.java
allowedOriginPatterns("*")
allowCredentials(true)
```

影响

生产环境允许任意来源跨域访问，不符合安全要求。

整改建议

生产只允许：

- 正式前端域名
 - 内部管理域名
 - 政务网或内网域名
-

P1-2 文件上传和下载安全不足

代码现状

文件上传只限制大小：

```
backend/src/main/java/com/trade/platform/module/file/service/FileService.java
file.getSize() > 5MB
```

没有统一白名单校验。

`/uploads/**` 被直接映射为静态资源：

```
backend/src/main/java/com/trade/platform/config/WebMvcConfig.java
registry.addHandler("/uploads/**")
```

影响

- 合同、报关委托书、营业执照等敏感文件可能被 URL 猜测访问。
- 上传恶意文件后存在安全风险。
- 删除记录不等于删除物理文件。

整改建议

- 文件下载必须走鉴权接口。
- 关闭公开静态 `/uploads/**`。
- 建立文件类型白名单。
- 增加 MIME 校验和扩展名校验。
- 增加病毒扫描。
- 采用对象存储，例如 MinIO。
- 文件访问使用临时签名 URL。

P1-3 前端路由声明了 roles，但路由守卫没有校验 roles

代码证据

路由声明：

```
frontend/src/router/index.js
roles: ['ADMIN', 'GUOHE']
```

路由守卫只检查 token：

```
frontend/src/router/index.js
router.beforeEach(...)
if (!token) next('/login')
```

影响

- 非授权用户可以直接访问路由页面。
- 虽然后端能拦截部分接口，但前端体验和安全模型不完整。

整改建议

- 前端路由守卫增加角色校验。
 - 后端仍作为最终权限判断。
 - 未授权跳转 403 页面。
-

P1-4 Token 存储在 localStorage

代码证据

```
frontend/src/utils/auth.js
localStorage.setItem(TOKEN_KEY, token)
```

影响

如果前端存在 XSS，Token 容易被读取。

整改建议

短期：

- 加强 XSS 防护。
- 避免 `v-html` 展示用户输入。
- 增加 CSP。

中期：

- 改为 HttpOnly Secure Cookie。

- 配套 CSRF 防护。
- 使用短 token + refresh token。

P1-5 多租户数据隔离还不够完整

现状

项目使用 MyBatis-Plus 租户拦截器，部分表通过 `tenant_id` 隔离。

但是以下表被忽略：

```
sys_user
sys_user_apply
sys_config_item
sys_config_value
biz_template
biz_order_goods
biz_customs_goods
biz_import_ledger_goods
biz_import_ledger_file
biz_customs_review
```

部分忽略是合理的，例如配置项；但部分关联表忽略后必须保证通过主表做权限校验，否则可能产生越权数据访问。

整改建议

- 对所有详情、下载、生成文档接口做租户归属校验。
- 关联表查询必须通过主表租户校验。
- 文件下载、单证下载必须校验租户。
- 国合员工跨租户访问必须有数据范围控制。

P1-6 API 错误码不规范

真实测试中，错误登录返回：

code=500 | 用户名或密码错误

这类业务错误不应是 500。

建议：

- 参数错误：400
- 未登录：401
- 无权限：403
- 资源不存在：404
- 业务失败：使用业务码，例如 10001
- 系统异常：500，但不返回内部堆栈

P1-7 前端构建包偏大

前端构建成功，但存在警告：

```
Some chunks are larger than 500 kB
index-f7LHQuFP.js 1,071.24 kB
```

影响：

- 首屏加载慢。
- 弱网下体验差。

建议：

- 路由级懒加载已经部分使用，但还需要进一步拆分。
 - Element Plus 按需加载。
 - 大型编辑器、OnlyOffice 相关组件异步加载。
 - 配置 chunk 拆分。
-

P1-8 前端依赖存在安全告警

运行：

```
npm audit --omit=dev
```

结果：

```
5 vulnerabilities
3 moderate
2 high
```

涉及：

- axios
- follow-redirects
- lodash
- lodash-es
- postcss

建议：

- 在测试环境执行依赖升级。
- 升级后重新跑前端构建和核心页面测试。
- 建立定期依赖安全扫描机制。

6. P2 级问题：工程质量和可维护性

P2-1 Java 版本说明不一致

README 中曾描述 Java 17，但 pom.xml 中：

```
<java.version>1.8</java.version>
```

本机用 Java 17 可以构建成功。

建议：

- 明确项目标准 JDK：建议统一为 Java 17。
 - 修改 pom.xml 的 java.version 为 17。
 - README、部署文档、CI 环境保持一致。
-

P2-2 依赖版本偏旧

当前：

```
Spring Boot 2.7.18  
jjwt 0.9.1  
Apache POI 4.1.2
```

建议：

- 短期保持 Spring Boot 2.7，先修业务问题。
 - 中期升级 Spring Boot 3.x。
 - JWT 库升级到新版本 jjwt-api / jjwt-impl / jjwt-jackson。
 - POI、EasyExcel 做兼容性验证后升级。
-

P2-3 交付包混入运行产物和日志

项目中包含：

- deploy/trade-platform-1.0.0.jar
- deploy/dist
- deploy/logs/app.log
- frontend/dist
- backend/target
- 测试临时文件

- IDE 配置
- 上传文件残留风险

建议：

- 建立根目录 `.gitignore`。
 - 源码仓库不提交 `target`、`dist`、`node_modules`、`logs`、`uploads`。
 - 交付包由 CI/CD 自动生成。
-

P2-4 缺少标准容器化部署

当前已经可以用 Docker 安装 MySQL，但项目本身没有：

- `Dockerfile`
- `docker-compose.yml`
- 环境变量模板
- 初始化脚本编排

建议增加：

```
docker-compose.yml
backend/Dockerfile
frontend/nginx.conf
.env.example
scripts/init-db.sh
```

P2-5 自动化测试不完整

已有 Python API 测试脚本，这是好事。

不足：

- Java 后端没有单元测试。
- 没有 Spring Boot 集成测试。

- 没有前端组件测试。
- 没有权限越权测试。
- 没有文件上传安全测试。
- 没有数据库迁移测试。

建议：

- 后端增加 JUnit + SpringBootTest。
 - API 测试纳入 CI。
 - 加入权限矩阵测试。
 - 加入多租户隔离测试。
 - 加入数据库 schema 校验测试。
-

7. 按 V1.0 需求文档的验收差距

7.1 登录注册

已有：

- 登录可用。
- 注册申请基本实现。
- 用户审批基本实现。

问题：

- 错误登录返回 500。
- 密码重置固定为 123456 。
- 注册角色可由前端提交。
- 重置密码申请与 SQL 的 password NOT NULL 设计冲突风险仍需确认。

7.2 用户与租户管理

已有：

- 用户列表、租户列表接口可用。

问题：

- 后端只允许 `ADMIN`，不符合“国合员工可管理”的需求。
- 租户删除、禁用的业务影响控制不足。
- 缺少完整审计。

7.3 配置管理

已有：

- 配置项、配置值列表可用。

问题：

- 初始化基础字典缺失。
- `COUNTRY` 等配置项未内置。

7.4 模板管理

已有：

- 模板列表部分可用。
- 代码中有上传、下载、预览、OnlyOffice 相关逻辑。

问题：

- 数据库字段缺失导致多个模板接口失败。
- 文件安全风险较高。
- OnlyOffice 回调存在安全隐患。

7.5 合同管理

已有：

- 合同列表可用。
- 临期合同接口可用。

不足：

- 合同文档生成能力需要结合模板字段修复后验证。
- 合同状态机控制较弱。
- 缺少审批、签署、归档、版本管理。

7.6 货物管理

已有：

- 列表、搜索、选择接口可用。

不足：

- 农产品特有字段不足，例如产地、批次、检测报告、冷链要求、保质期、规格等级。

7.7 订单管理

已有：

- 订单列表可用。

不足：

- 订单与合同状态强约束需要加强。
- 订单生成发票、箱单、报关草单需要结合模板和台账修复后验证。

7.8 报关单管理

已有：

- 报关导入、列表、审核流程代码存在。

问题：

- 列表接口当前不可用。
- SQL 缺字段。
- 需求文档要求报关单导入后只读，但当前代码存在创建、更新、删除、审批、放行等接口，需要重新确认业务边界。

7.9 文件管理

已有：

- 文件列表接口可用。

问题：

- 上传安全不足。
- 下载鉴权和公开目录风险需要整改。

7.10 权限管理

已有：

- 简单角色注解。
- JWT 拦截器。

不足：

- 不完整 RBAC。
- 前后端权限不一致。
- 多租户数据范围需加强。

7.11 供应商与客户管理

已有：

- 列表、供应商、客户、活跃数据接口可用。

不足：

- 联系人、地址、资信、交易历史、风险等级等字段不足。

7.12 退税管理

当前是静态页。

这符合需求文档 V1.0 中“仅展示条款，无逻辑代码”的要求。

但如果目标是省级外综服平台，退税管理必须升级为真实业务模块。

8. 与省级外贸综合服务平台目标的差距

当前 V1.0 需求本身是一个较小范围的关贸 SaaS，不是完整省级平台。

如果杨凌国合要做省级外综服平台，应补齐以下能力。

8.1 企业服务闭环

应形成完整链条：

企业入驻
资质审核
客户/供应商管理
商品备案
合同
订单
单证
报关
物流
收汇
结汇
退税
信保
融资
风控
归档
统计分析

当前只有前半段基础信息和部分单证/报关雏形。

8.2 农产品外贸特色能力

作为国有农产品外贸企业，建议重点建设：

- 农产品批次管理
- 产地管理
- 合作社/基地管理
- 农残检测报告

- 植检证/原产地证管理
- 冷链温控记录
- 保质期和库存批次
- 质量追溯码
- 目的国准入规则
- 农产品价格指数
- 质量争议处理

8.3 外部系统衔接

V1.0 需求明确暂不做第三方 API，但省级平台必须规划接口：

- 中国国际贸易单一窗口
- 电子口岸
- 海关回执
- 税务退税系统
- 外汇/银行
- 物流/货代
- 中国信保
- 商务部门统计报送
- 企业 ERP/财务系统

8.4 资金流能力

外综服平台不能只有单证流，还应管理资金流：

- 应收账款
- 收汇登记
- 结汇
- 汇率损益
- 付款申请

- 付汇资料
- 逾期预警
- 退税到账
- 融资还款

8.5 风控能力

建议建立风险引擎：

- 企业风险
- 买方风险
- 国家风险
- 商品风险
- 价格异常
- 单证不一致
- 收汇逾期
- 退税异常
- 敏感国家/地区
- 高风险客户名单

8.6 监管和运营驾驶舱

省级平台应具备：

- 企业数量
- 进出口额
- 商品结构
- 目的国分布
- 农产品品类分析
- 报关量
- 退税额

- 融资额
 - 风险事件
 - 服务时效
 - 国合员工工作量
-

9. Rust 重构建议

9.1 不建议现在全量 Rust 重写

原因：

1. 当前最大问题是数据库、权限、安全和业务闭环，不是 Java 性能。
2. Java/Spring Boot 更适合当前这种后台管理、流程、表单、报表、权限系统。
3. 团队基础较弱时，全量 Rust 会显著增加学习和维护成本。
4. 全量重写会把已经实现的页面和接口推倒重来，周期长、风险大。

9.2 推荐路线

短期：

- 保留 Java/Spring Boot。
- 修复 1.0。
- 做到可运行、可验收、可试点。

中期：

- 对高性能、高安全模块引入 Rust。

适合 Rust 的模块：

- 大文件 Excel/CSV 导入解析
- 单一窗口数据解析
- 报关单批处理
- 文档转换

- 文件 hash 和病毒扫描前置
- 风控规则计算
- 数据同步 Agent
- API 签名验签网关

长期：

- Java 负责业务编排和后台管理。
 - Rust 负责高性能数据处理和安全敏感服务。
 - 通过 HTTP/gRPC/消息队列连接。
-

10. 推荐整改路线图

第 0 阶段：立即修复，1 到 2 周

目标：让 1.0 真正可运行。

必须完成：

- 补齐数据库表和字段。
- 修复模板接口失败。
- 修复报关接口失败。
- 修复台账接口失败。
- 补齐基础配置数据。
- 修复错误登录返回 500。
- 修复 JWT 过期时间。
- 禁止注册接口直接申请管理员角色。
- 修改默认密码和重置密码机制。
- 关闭异常详情返回。

验收标准：

- `tests/check_all_apis.py` 全部核心接口通过。

- 台账接口通过。
- 模板上传/下载/预览通过。
- 报关列表和导入通过。
- 前后端能一键启动。

第 1 阶段：1.1 试点版，1 到 2 个月

目标：具备小范围企业试点能力。

重点：

- 引入 Flyway/Liquibase。
- 完善 RBAC。
- 增加操作日志。
- 增加数据权限测试。
- 文件中心改为鉴权下载。
- 增加 MinIO。
- 完善合同、订单、报关、文件的业务状态机。
- 做 Docker Compose 一键部署。
- 建立 CI/CD。

第 2 阶段：1.5 业务闭环版，3 到 6 个月

目标：形成外贸业务闭环。

重点：

- 合同、订单、单证、报关、物流、收汇、退税串起来。
- 建立服务工单。
- 建立客户经理/单证员/财务/风控协同流程。
- 建立农产品批次和质检管理。
- 建立基础驾驶舱。
- 建立风险预警。

第 3 阶段：2.0 省级平台版，6 到 18 个月

目标：从企业内部系统升级为省级外综服平台。

重点：

- 多机构接入。
 - 多角色数据范围。
 - 银行/信保/物流/单一窗口对接。
 - 数据仓库。
 - 监管驾驶舱。
 - 风控引擎。
 - 等保测评。
 - 灾备和高可用。
-

11. 部署架构建议

11.1 本地开发环境

当前本机已有：

- Java 17
- Maven
- Node/npm
- Docker
- Docker MySQL

本地还可以暂不安装：

- Nginx
- Redis
- OnlyOffice

原因：

- Nginx 主要用于生产部署。
- Redis 当前代码没有强依赖。
- OnlyOffice 只影响在线编辑，不影响基础业务验证。

11.2 试点环境

建议：

- 应用服务器 1 到 2 台
- MySQL 8
- MinIO
- Nginx
- HTTPS
- 每日备份
- 日志集中存储

11.3 生产环境

建议：

- 负载均衡 2 台
 - 应用节点 3 台起
 - MySQL 主从或高可用
 - Redis 高可用
 - MinIO 4 节点
 - 日志监控平台
 - WAF
 - 堡垒机
 - 数据库审计
 - 异地备份
-

12. 建议开发商提交的整改材料

请开发商补交：

1. 完整数据库设计文档。
 2. 当前源码对应的完整建表 SQL。
 3. 每个版本的数据库迁移脚本。
 4. 权限矩阵表。
 5. 接口文档。
 6. 部署文档。
 7. 测试报告。
 8. 安全整改说明。
 9. 默认账号和初始化密码策略说明。
 10. 文件上传和下载安全方案。
 11. OnlyOffice 安全接入方案。
 12. 多租户隔离测试报告。
-

13. 给国合内部的管理建议

13.1 不要只看页面

外贸平台验收不能只看“页面有没有”，必须看：

- 数据是否隔离
- 流程是否闭环
- 权限是否正确
- 单据是否可追溯
- 文件是否安全
- 报错是否可定位
- 数据库是否完整

- 部署是否可重复

13.2 建立业务验收清单

每个模块都要有：

- 业务流程图
- 字段表
- 状态流转表
- 权限表
- 测试用例
- 异常场景
- 验收标准

13.3 建议成立小组

建议至少包括：

- 国合业务负责人
- 单证员
- 报关业务人员
- 财务/退税人员
- 风控人员
- 技术负责人
- 测试人员
- 运维人员

14. 当前优先整改清单

第一优先级

1. 补齐数据库表字段。

2. 引入数据库迁移工具。
3. 修复接口冒烟测试失败项。
4. 修复台账模块。
5. 修复 JWT 过期时间。
6. 修复角色申请越权。
7. 关闭异常详情泄露。

第二优先级

1. 完善国合员工权限。
2. 完善前端路由权限。
3. 文件中心安全整改。
4. OnlyOffice 安全整改。
5. 初始化配置数据。
6. 前端依赖漏洞升级。

第三优先级

1. Docker Compose。
2. CI/CD。
3. 自动化测试。
4. 代码分包优化。
5. 日志和监控。
6. 数据备份。

15. 复查结论

当前项目已经不是“环境跑不起来”的阶段。现在可以确认：

- 环境已就绪。
- 前端能构建。

- 后端能构建。
- 后端能启动。
- 登录和多数基础接口可用。

但是也可以确认：

- 数据库脚本与源码不一致。
- 关键业务模块存在运行时错误。
- 安全设计不能直接上线。
- 权限模型不满足需求文档。
- 省级平台能力远未完成。

建议不要继续堆新功能，先做一次 1.0 稳定性和安全整改。整改完成后，再规划 1.5 和 2.0，而不是直接 Rust 重写或盲目扩模块。

本报告建议作为开发商整改、内部验收和后续省级平台规划的基础材料。

本文档为内部研究和项目推进资料，请结合正式政策文件、合同文本和业务凭证审慎使用。